

Laporan Monitoring P7

Proyek PBL Keamanan Informasi KOM1315

Nama sistem: TUMBUH

Kelompok 9:

Ghiffari Bravia Hisham - G6401231050

Adam Naufal - G6401231082

Rafif Muhammad Farras - G6401231102

Ringkasan

Laporan Monitoring P7 ini sebagai laporan kemajuan proyek Keamanan Informasi untuk sistem TUMBUH sampai minggu ke-7. Pada tahap ini, kelompok telah menyelesaikan baseline analisis sistem, threat modeling, dan rancangan awal integrasi keamanan.

Sampai minggu ke-7, implementasi keamanan yang sudah berjalan pada sistem utama adalah Authentication dan Authorization. Authentication telah diarahkan untuk mendukung login, registrasi, penyimpanan password secara aman, dan penggunaan token. Authorization telah diarahkan untuk membatasi akses berdasarkan peran pengguna dan kepemilikan data. Kedua kontrol tersebut tidak dibuat sebagai skrip terpisah, tetapi langsung diintegrasikan ke workflow utama aplikasi TUMBUH.

Komponen Accounting atau audit logging belum diimplementasikan sampai minggu ke-7. Accounting masih menjadi rencana lanjutan untuk minggu berikutnya agar aktivitas penting pengguna dapat dicatat sebagai audit trail.

Bab 1. Pendahuluan

1.1 Latar Belakang

TUMBUH adalah aplikasi web Career & Internship Tracker yang dirancang untuk membantu mahasiswa IPB mencari lowongan kerja, magang, dan peluang pengembangan karier. Sistem ini juga menyediakan fitur bagi HR perusahaan untuk mengelola profil perusahaan, membuat lowongan, melihat pelamar, dan memperbarui status lamaran. Admin platform berperan melakukan pengawasan terhadap data pengguna dan aktivitas sistem.

Karena TUMBUH menangani data pribadi mahasiswa, data perusahaan, CV, status lamaran, dan akun pengguna, sistem membutuhkan kontrol keamanan yang jelas. Risiko utama pada sistem seperti ini meliputi pencurian akun, akses tidak sah, manipulasi status lamaran, kebocoran data pribadi, dan tidak adanya bukti aktivitas ketika terjadi insiden.

Monitoring P7 difokuskan pada evaluasi progres awal proyek, terutama hasil analisis, rancangan keamanan, dan implementasi awal yang sudah terintegrasi ke sistem.

1.2 Tujuan Laporan

Tujuan laporan Monitoring P7 adalah:

- Menjelaskan kondisi dan kebutuhan keamanan TUMBUH sampai minggu ke-7.
- Merangkum hasil analisis sistem dan ancaman utama.
- Mendokumentasikan progres implementasi Authentication dan Authorization.
- Menjelaskan bahwa Accounting belum menjadi bagian implementasi minggu ke-7.
- Menjadi baseline sebelum pengembangan keamanan lanjutan pada minggu berikutnya.

1.3 Ruang Lingkup

Ruang lingkup monitoring mencakup:

- Analisis kebutuhan keamanan sistem TUMBUH.
- Threat modeling untuk aktor mahasiswa, HR, admin, dan pengguna tidak sah.
- Progres integrasi Authentication ke backend dan frontend.
- Progres integrasi Authorization berbasis role dan ownership.
- Rencana lanjutan untuk Accounting, enkripsi data sensitif, dan digital signature.

Ruang lingkup ini belum mencakup implementasi lengkap audit logging, enkripsi data sensitif, digital signature, maupun log pengujian end-to-end.

Bab 2. Analisis Sistem dan Risiko

2.1 Ringkasan Sistem

TUMBUH memiliki tiga aktor utama:

Aktor	Peran dalam sistem	Data atau fitur yang perlu dilindungi
Mahasiswa	Membuat profil, melihat lowongan, menyimpan lowongan, dan mengirim lamaran	Profil pribadi, NIM, CV, riwayat lamaran, status seleksi
HR perusahaan	Mengelola profil perusahaan, membuat lowongan, dan meninjau pelamar	Data perusahaan, lowongan, data pelamar, status lamaran
Admin platform	Mengawasi pengguna, perusahaan, dan konten platform	Data pengguna, data perusahaan, aktivitas administratif

Alur utama sistem dimulai dari pengguna yang mengakses frontend, mengirim request ke backend API, lalu backend melakukan validasi dan mengambil atau memperbarui data pada database. Berdasarkan analisis awal, titik kontrol keamanan utama berada pada proses login, validasi token, pengecekan role, pengecekan ownership, dan pencatatan aktivitas penting.

2.2 Aset yang Dilindungi

Aset penting yang diidentifikasi pada tahap analisis meliputi:

- Akun pengguna, termasuk email, password, dan role.
- Profil mahasiswa, termasuk nama, NIM, jurusan, kontak, GPA, dan CV.
- Data perusahaan dan lowongan yang dikelola HR.
- Data lamaran dan perubahan status seleksi.
- Konfigurasi keamanan seperti secret key dan kredensial database.
- Bukti aktivitas pengguna yang nantinya akan dicatat melalui audit log.

2.3 Risiko Utama

Hasil threat modeling menunjukkan beberapa risiko prioritas:

Risiko	Dampak	Mitigasi yang direncanakan
Authentication lemah	Pengambilalihan akun pengguna	Password hashing, validasi login, JWT, token expiration
Endpoint tidak membatasi role	Mahasiswa, HR, atau admin dapat mengakses fitur di luar haknya	Role-based access control
Tidak ada ownership check	Pengguna dapat mengakses data milik pengguna atau perusahaan lain	Validasi kepemilikan data pada backend
Password disimpan tidak aman	Password dapat bocor jika database terekspos	Hashing dan salting
Aktivitas penting tidak tercatat	Investigasi insiden sulit dilakukan	Accounting/audit logging pada tahap lanjutan
Perubahan status lamaran tidak memiliki bukti integritas	Pengguna dapat menyangkal perubahan data	Audit trail dan digital signature pada tahap lanjutan

2.4 Prioritas Keamanan

Berdasarkan risiko tersebut, prioritas keamanan sampai minggu ke-7 diarahkan pada dua fondasi utama:

1. **Authentication**, agar sistem dapat memastikan identitas pengguna sebelum memberikan akses.

2. **Authorization**, agar sistem dapat memastikan pengguna hanya mengakses fitur dan data sesuai perannya.

Accounting belum menjadi capaian minggu ke-7 karena prioritas awal difokuskan pada pencegahan akses tidak sah terlebih dahulu. Accounting akan dilanjutkan setelah alur identitas dan hak akses stabil.

Bab 3. Progres Implementasi Hingga Minggu ke-7

3.1 Status Umum Progres

Sampai minggu ke-7, kelompok telah menyelesaikan dokumen proposal teknis, threat modeling, rancangan awal keamanan, dan integrasi awal Authentication serta Authorization pada aplikasi. Implementasi dilakukan langsung pada alur utama aplikasi, bukan sebagai modul demonstrasi yang berdiri sendiri.

Komponen AAA	Status P7	Keterangan
Authentication	Sudah dilakukan dan terintegrasi	Login, register, password hashing, JWT, refresh token, dan proteksi endpoint sudah diarahkan ke workflow utama
Authorization	Sudah dilakukan dan terintegrasi	Pembatasan akses berdasarkan role dan ownership sudah diarahkan pada endpoint dan route penting
Accounting	Belum dilakukan	Audit logging belum menjadi bagian implementasi minggu ke-7 dan direncanakan untuk tahap berikutnya

3.2 Progres Authentication

Authentication sampai minggu ke-7 telah difokuskan pada validasi identitas pengguna. Implementasi yang sudah dilakukan meliputi:

- Registrasi pengguna dengan data akun dan role.
- Login menggunakan email dan password.
- Penyimpanan password menggunakan hashing dan salting.
- Penerbitan access token dan refresh token.
- Validasi token untuk mengakses endpoint yang membutuhkan autentikasi.
- Integrasi token dari frontend ke request backend.

Pada backend, Authentication terhubung dengan service autentikasi, skema user, route login/register, dan dependency untuk mengambil current user. Pada frontend, Authentication

terhubung dengan halaman login, halaman register, context pengguna, dan API client yang membawa token pada request.

Dengan integrasi ini, pengguna tidak hanya diverifikasi pada tampilan frontend, tetapi juga pada backend. Hal ini penting karena backend tetap menjadi titik validasi utama dan tidak mempercayai role atau identitas hanya dari input client.

3.3 Progres Authorization

Authorization sampai minggu ke-7 telah difokuskan pada pembatasan akses berdasarkan role dan ownership. Role utama yang digunakan adalah:

- student untuk mahasiswa.
- hr untuk pihak perusahaan.
- admin untuk pengelola platform.

Implementasi Authorization yang sudah dilakukan meliputi:

- Proteksi endpoint berdasarkan role pengguna.
- Pemisahan route atau dashboard berdasarkan role di frontend.
- Pembatasan fitur mahasiswa, HR, dan admin.
- Ownership check pada data yang berkaitan dengan perusahaan, lowongan, dan lamaran.
- Penolakan akses ketika pengguna mencoba mengakses fitur yang bukan haknya.

Contoh integrasi Authorization adalah HR hanya dapat mengelola data yang terkait dengan perusahaannya, sedangkan mahasiswa hanya dapat mengakses alur yang relevan dengan profil dan lamarannya sendiri. Admin memiliki akses administratif yang lebih luas, tetapi tetap dipisahkan dari alur mahasiswa dan HR.

3.4 Status Accounting

Accounting belum diimplementasikan sampai minggu ke-7. Artinya, pada status P7 sistem belum memiliki audit trail final yang mencatat aktivitas penting seperti:

- Login berhasil dan gagal.
- Perubahan profil pengguna.
- Pembuatan atau perubahan lowongan.
- Perubahan status lamaran.
- Aktivitas admin.

Ketiadaan Accounting pada minggu ke-7 masih dicatat sebagai gap implementasi. Gap ini penting karena tanpa audit trail, sistem belum memiliki bukti aktivitas yang cukup untuk investigasi insiden dan non-repudiation. Accounting direncanakan menjadi fokus pengembangan setelah Authentication dan Authorization stabil.

3.5 Bukti Integrasi ke Sistem

Bukti integrasi Authentication dan Authorization dapat dilihat dari struktur source code yang sudah ditempatkan pada folder 03_Source_Code, terutama:

- 03_Source_Code/src/auth/ untuk bukti alur login, token, role, dan proteksi akses.

- 03_Source_Code/backend/ untuk integrasi endpoint, service, schema, dan dependency backend.
- 03_Source_Code/database/ untuk bukti skema user, role, dan kolom password yang disimpan dalam bentuk hash.

Bukti tersebut menunjukkan bahwa kontrol keamanan awal sudah masuk ke aplikasi utama TUMBUH. Namun, folder tersebut belum menjadi bukti bahwa Accounting selesai pada minggu ke-7.

Rencana Lanjutan Setelah P7

Setelah monitoring P7, pekerjaan keamanan yang perlu dilanjutkan adalah:

3. Mengimplementasikan Accounting atau audit logging untuk aktivitas penting.
4. Menyusun log pengujian Authentication dan Authorization.
5. Menguji bahwa pengguna tanpa hak akses gagal mengakses endpoint protected.
6. Mengidentifikasi data sensitif yang perlu dienkripsi.
7. Mengintegrasikan enkripsi dan dekripsi pada workflow utama.
8. Menambahkan digital signature untuk aksi penting seperti perubahan status lamaran.
9. Menyusun testing log end-to-end untuk mendukung luaran minggu 11-12.

Kesimpulan

Sampai minggu ke-7, proyek TUMBUH telah memiliki baseline analisis dan rancangan keamanan. Authentication dan Authorization telah dilakukan dan langsung diintegrasikan ke sistem utama. Authentication mendukung validasi identitas pengguna melalui login, hashing password, dan token. Authorization mendukung pembatasan akses berdasarkan role dan kepemilikan data.

Namun, AAA Security belum lengkap pada tahap P7 karena Accounting belum diimplementasikan. Accounting akan menjadi *task* lanjutan agar aktivitas penting pengguna dapat dicatat dan digunakan untuk investigasi keamanan maupun kebutuhan non-repudiation.